

从手环到网页

Fitbit Air 健康数据部署教程

Google Health API · Linux · OAuth · AI · MCP

- 01 接入** 配置 Google Cloud, 安全获得自己的健康数据
- 02 呈现** 同步当天数据, 组织运动、睡眠与长期趋势
- 03 分析** 加入自由问答、图片、健康指导和每周回顾
- 04 维护** 登录隔离、脱敏分享、备份恢复与问题排查

可跟学 · 已脱敏 · 含参考源码包

不包含真实账号、访问凭据、服务器地址、健康记录或 GPS 轨迹。

先读这一页

把已经走通的实践，整理成别人能够复现、也能够判断风险的教程。

你将完成什么

用自己的 Google 账号授权，读取 Fitbit 等兼容设备已上传到 Google 的健康数据；在一台 Linux 服务器保存并呈现数据；再按需接入 AI、只读 MCP、日报与周报。浏览器不直接持有 Google 令牌。

适合谁

适合拥有兼容设备、能够使用 SSH 和基本 Linux 命令的个人开发者。主线为“单用户私有网站”，不是供陌生人注册的健康 SaaS，也不是医院病历系统。设备和账号实际可读的数据可能不同。

交付文件	用途
本 PDF	操作步骤、原理、验收方式、故障排查和隐私边界。
Air-Health-Tutorial-Source.zip	脱敏参考源码，含新安装脚本、登录网关配置工具、静态页面与定时任务示例。
源码中的 SHA256SUMS.json	核对所用快照的文件完整性；它不是安全认证或可信签名。

本教程不含真实账号或健康记录。 所有主机名、域名、邮箱和时间样例均为教学占位；不要把示例 IP 当成实际服务器。不要向他人发送自己的 token.json、config.json、auth.json 或健康备份。

版本与验证范围

官方资料核对日期：2026-09-08。应用部分来自本次核对的工作区快照，未冒充通用正式发行版。完成了源码脱敏、离线检查和 PDF 排版验证；没有为此教程重新购买服务器、授权新账号或实测所有数据类型。

命令默认在 Linux 服务器执行；标注“本机 PowerShell”的命令在自己的电脑执行。个人资料、健康建议和 AI 推断不能替代专业医疗评估。

目录与学习路线

点击下方章节可跳转；PDF 侧栏也提供逐页书签。

一、架构、准备与免费云服务器	04 - 10
二、Google Cloud 项目与只读权限	11 - 12
三、安装服务、OAuth 授权及常见错误	13 - 16
四、同步接口、当天数据与存储设计	17 - 19
五、页面组织、运动详情与手机体验	20 - 22
六、登录网关与 HTTPS 公网访问	23 - 24
七、AI 接入、问答、图片与健康指导	25 - 28
八、通过 MCP 读取健康数据	29 - 29
九、周报、定时任务与备份恢复	30 - 32
十、排障、安全、扩展与最终验收	33 - 36
参考资料与继续学习	37 - 39

最短可用路径：6 → 7 至 10 (无服务器时) → 11 → 12 → 13 → 14 → 15 → 18 → 20。 先在 SSH 隧道内确认同步成功，再增加公网入口。AI 与 MCP 均为可选增强。

建议每完成一节就执行该节的验收检查。出现问题时，从最近一个已验证环节向后排查；不要同时改回调、端口、域名、权限与模型。

系统架构：数据怎样到网页

两条授权链、三个服务端口、一个私有数据目录。



手环先与手机同步，再由云端 API 提供数据。网页上的“同步数据”是让服务器查询云端，**不是远程触发手环蓝牙同步**。后台既保留可追溯记录，也生成便于展示的日汇总。

组件	边界
127.0.0.1:8765	主应用与首次 OAuth 配置。只通过 SSH 隧道访问，不向公网直接开放。
127.0.0.1:8766	带登录的网页网关；HTTPS 隧道只代理这里。
Unix socket / AI 用户	主应用发送精简摘要，隔离的 AI broker 调用模型；不把 Google 凭据交给模型。

Google OAuth 解决“谁允许读取手环数据”；网站登录解决“谁可以浏览面板”；AI 登录解决“谁承担模型访问权限与费用”。三者不能互相代替。

数据范围：能访问不等于有记录

先区分云端 API 能力、设备传感器、用户记录和当前代码覆盖范围。[S2][S3]

类别	可组织的数据	限制或补充来源
活动与训练	步数、距离、楼层、活动热量、活跃分钟、心率区间、运动会话、部分 VO $\square$ max 与游泳记录	不同设备、运动类型及 API 操作支持不同。
睡眠与恢复	睡眠时段、分期、总时长、静息心率、夜间 HRV、呼吸率、血氧与皮温变化	夜间派生指标通常不是实时值；短睡眠可能没有完整分期。
身体测量	体重、体脂、身高、核心体温、血糖等已有记录	有接口不意味着手环能测量；可能依赖手动记录或其他设备。
营养与饮水	饮水日志、饮食日志、关联的食物与计量单位	未记饮食就不会自动形成完整营养档案。
设备与资料	设备名称、电量、最后同步时间、个人资料	单独的 settings / profile 权限；展示时避免暴露设备 ID。
路线、ECG、IRN	运动 GPS 路线、心电记录、心律不齐通知	高敏感且强依赖设备、地区与账号；默认不向 AI 提供精确位置。

不要宣传 Fitbit Air 能直接测尿酸或血糖。 当前授权列表也不能证明某台设备具备这些测量能力。尿酸应来自有效的化验记录；血糖需要可信的手动或设备来源。无记录必须显示“未提供”，不能让 AI 补造。

教程快照尝试覆盖多类原始记录、日指标与会话；“同步全部可访问数据” 仍应解释为：当前已实现接口中，账号授权且 API 实际返回的记录。今后新增 API 类型要另外开发和验证。

准备清单与示例约定

准备项	要求与检查
设备和手机	先在官方手机应用中确认已出现活动或睡眠数据，并确认登录账号。
Google 账号	能创建 Cloud 项目、配置 OAuth；使用真正关联设备数据的账号授权。
Linux 服务器	推荐熟悉的 Ubuntu / Debian 与 systemd；Python 3、SSH、可信 CA、可用磁盘。具体资源按原始数据量调整。
网络	服务器能通过合法可用的网络访问 Google OAuth、Health API；使用 AI 时另需模型服务连通性。
可选组件	AI 账号与官方 Codex CLI；公网访问用 cloudflared 或自有 HTTPS 反向代理。

Linux 服务器：基础检查

```
sudo apt update
sudo apt install -y python3 ca-certificates unzip curl
python3 --version
timedatectl status
df -h /var/lib
getent hosts health.googleapis.com
curl -I --connect-timeout 10 https://health.googleapis.com
```

HTTP 404 或 401 可以说明目标服务器已响应，并不等于授权成功；DNS、TLS 或连接超时要先解决。不要关闭证书校验。首次回填一年记录可能明显慢于后续增量同步。

全文占位约定：服务器别名 health-server；管理员 ubuntu；文档保留 IP 203.0.113.10；网站 health.example.com；示例邮箱 reader@example.com。请替换为你自己的信息，保留 localhost 回调的精确形式。

本教程不提供跨地区访问承诺，也不代表规避服务适用地区或使用条款。公网数据经过代理服务时，也要考虑该服务的隐私政策。

没有服务器？先选免费或低成本方案

免费额度是有条件的资源优惠，不是无限使用、永不停机或永不收费的承诺。

方案	适合什么	先看限制
Google Cloud Free Tier	学习 Linux 部署、个人低流量看板；下面给出配置主线	合资格 e2-micro 与标准磁盘有额度；IP、流量等仍可能收费。[S15][S16]
Oracle Always Free	申请成功且有容量时，可考虑兼容的个人服务	主区域、机型、资源总额与空闲回收；Arm 还需核对 CLI 架构。[S19]
旧电脑 / Linux 小主机	已有设备，希望优先本地保存数据	不用另买云主机，但有电费、网络、持续开机和异地备份成本。
临时试用 / 免费托管平台	短期学习和演示	先看是否休眠、是否有持久磁盘；不是所有平台都支持 systemd 与 SQLite 常驻写入。

Google 的两种“免费”不是一回事

Free Trial: 符合资格的新用户试用，当前为 90 天、300 美元额度；需要验证身份和有效支付方式。试用结束前未升级，相关资源会停止。

Free Tier: 特定产品的月度用量额度，需要有效 Billing 账号。付费账号超额会计费；计划目前没有固定结束日期，但 Google 可以调整规则。[S15]

推荐学习顺序

先完成小范围数据同步和网页查看，再开启大量原始记录回填、定时备份和 AI。对预算极其敏感、不能接受任何云端附加费用的读者，优先考虑已有 Linux 设备；不要把“有免费实例”理解为整套架构保证 0 元。

用户提供的知乎文章作为选题线索：本次访问返回 403，未能核验正文，不转述其中步骤或把它作为价格依据。文末保留该链接，实际配置以官方控制台与定价为准。

Google 免费额度虚拟机：配置步骤

这一步只创建自己的服务器；后面的 Google Health OAuth 仍需用户授权。[S15][S21]

1. 在自己的 Google Cloud 账号创建专用项目并关联有效 Billing。先区分试用账号和已升级付费账号，再启用 Compute Engine API。可与 Health API 使用同一项目，便于学习；服务账号身份不能代替个人健康数据 OAuth。
2. 进入 Compute Engine → VM instances → Create instance。不要直接接受默认机型与默认磁盘，按下表逐项检查，再查看创建页的价格估算。

设置	免费额度主线配置
区域	us-west1 (Oregon)、us-central1 (Iowa) 或 us-east1 (South Carolina) 三选一；不是所有美国区，也不是香港/新加坡区。
机型 / 供应模式	E2 → e2-micro；标准、非抢占式实例。不要误选 e2-small、e2-medium 或 Spot。
实例时长	按 Billing 账号合并 eligible 实例使用时长，每月额度相当于一台持续运行；不是每个项目各送一台。
系统与磁盘	选择无额外许可费的 Ubuntu / Debian 镜像；Standard persistent disk (pd-standard)。合计额度 30 GB-month，注意不是 Balanced、SSD 或 Hyperdisk。
网络与防火墙	先阅读下一页再决定公网 IP。SSH 仅允许可信来源或受控访问；不要开放 8765 / 8766，不必为 Cloudflare 出站隧道开放网页入站端口。

3. 创建前检查地区、机型、磁盘类型、额外数据盘、快照计划、IP 和网络价格。估算显示目录价不等于最终账单，也不能仅凭预计折扣认为所有项目免费；创建后在 Billing Reports 查看 SKU 与抵扣。
4. 创建成功后，通过控制台 SSH 或自己已验证的 SSH 密钥登录，执行前文基础环境检查。将后面命令中的 health-server 替换成自己的 SSH 别名，继续“Google Cloud：创建正确的项目”和基础安装步骤。

教程没有替读者开通 Billing 或创建资源。请自行核对资格、支付验证和创建页信息；不要购买共享云账号，不要在教程评论中提供银行卡、账号或 SSH 私钥。

免费算力之外：IP、联网与防扣费

最容易遗漏：公网 IPv4

标准 VM 的在用静态或临时公网 IPv4 当前标价为每小时 0.005 美元，月度免费仅 1 小时。按 730 小时估算，仅这一个 IP 约 3.65 美元/月，尚未计其他项目。停止 VM 不一定释放静态 IP，闲置预留地址也可能继续收费。
[S16]

联网方案	权衡
公网 IPv4 + SSH + HTTPS 隧道	容易理解，但属于“免费算力 + 可能收费网络”，不能写成永久免费服务器。
不分配公网 IPv4，使用可用 IPv6	IPv6 地址本身当前不收费，但需验证 DNS、软件源、Google OAuth/Health、模型服务与 cloudflared 的全链路 IPv6 能力。不能保证原教程零改动可运行。
私有 VM + Cloud NAT / 中转	能解决某些出站需求，但 NAT、IP、中转机与流量可能另外收费。SSH/IAP 的入站能力不等于通用互联网出站能力。

磁盘、流量与 AI 也要分别算

检查持久磁盘、额外磁盘、快照、日志、出口流量、DNS 和备份存储。Compute Engine 免费计划列出的出口额度为每月 1 GB，从北美到目的地区域不含中国和澳大利亚；实际还要按所选网络层级与目的地核算。Cloudflare 隧道不会自动免除 Google 出口费用。AI 账号费用另算。
[S15][S16]

开通后立刻设置成本观察

创建小额月度预算，例如 5 美元，并启用 50%、90%、100% 邮件提醒；前几天按服务/SKU查看计费。**普通 Alerts-only 预算不会自动封顶**。预览版 spend cap 仅覆盖特定 API 服务且存在延迟，不会停止持续的计算或存储计费，不能替 VM 保证零账单。
[S17][S18]

不再使用时，先备份并确认恢复方案，再逐项检查实例、保留磁盘、快照、预留 IP、NAT 与其他资源。只关机不是“清零费用”。不要把自动停机作为健康数据可靠性的唯一保障。

小规格运行策略与其他免费选项

e2-micro 先跑基础功能

官方规格为约 1 GB 内存、共享 CPU；2 个可见 vCPU 不等于 2 个持续满速核心。[\[S20\]](#) 以下是针对本项目的工程建议，不是性能实测或云厂商保证：

阶段	建议
首次部署	先回填 7 至 30 天，验证步数、睡眠和少量运动；不要首次就并发回填多年逐点心率。
日常运行	保留单一同步任务入口；同一时刻只做一种重任务，错开回填、备份和 AI。
AI 分析	本项目调用远端模型，不在 VM 上部署大模型。CLI 本身也占内存；先关闭定时 AI，测试后再启用。
磁盘与保留	按需保留高频原始数据、限制日志与备份份数；注意备份副本会与原数据竞争 30 GB 磁盘。
稳定性	出现 OOM、延迟或磁盘不足，先减少任务和范围；必要时升级或迁移，不能为了“免费”牺牲数据可靠性。

Linux：检查内存、磁盘以及内核 OOM 等事件

```
free -h
df -h /var/lib/air-health
sudo journalctl -k -n 100 --no-pager
```

Oracle Always Free：备选，不承诺能申请到

当前官方列有最多两台 AMD Micro，或共享额度内的 Arm A1 计算资源；A1 页面所列额度相当于 2 OCPU / 12 GB，并有合计块存储额度。创建须在主区域，容量可能不足，空闲实例可能被回收。不要直接沿用旧文章的更大配额，也不要制造虚假负载规避回收。[\[S19\]](#)

Arm 方案先验证 Python、Codex CLI 和 cloudflared 的对应架构支持；保留异地加密备份。Cloud Shell 适合配置操作，不应当作常驻服务器；Cloud Run 等服务则需重新设计持久存储与定时任务，不能原样复制 systemd 教程。

选定服务器后，后续数据权限、OAuth、私有存储与登录保护完全不变。“免费”不能降低健康数据保护标准。

Google Cloud: 创建正确的项目

本项目使用 `health.googleapis.com`，不是 Cloud Healthcare API，也不是照搬旧 Google Fit 接口。[S1][S5]

1. 创建项目并启用 API

进入 Google Cloud Console，创建独立项目，例如 `health-demo`。确认顶部项目选择器正确。在“API 和服务 → 库”搜索 Google Health API，核对服务名称 **health.googleapis.com**，然后启用。不要仅凭相似名称选择 Healthcare API。

2. 配置 Google Auth Platform

按控制台向导填写应用名称、用户支持邮箱和开发者联系邮箱。个人 Gmail 场景通常选择 External；学习阶段保持 Testing。进入 Audience（受众），把将要授权的账号加入 Test users 并保存。[S1][S7]

3. 创建 OAuth 客户端

进入 Clients（客户端）或“API 和服务 → 凭据”，创建 OAuth 2.0 Client ID，类型选 Web application。给客户端起一个无个人信息名称。把下方地址加入“已获授权的重定向 URI”，不要误填到 JavaScript 来源中。

本教程参考应用要求的精确 redirect URI

`http://localhost:8765/oauth/callback`

4. 保存 Client ID 和 Client Secret

妥善保存凭据文件；下一阶段通过 SSH 隧道在服务端初始化页面输入。不要把 Client Secret 写入 `static/app.js`、公开仓库、博客或聊天截图。Client ID 也建议在分享材料中替换为占位符。

不要为了绕过错误直接切换到正式发布。 个人测试先配置测试用户并完成自己的授权。对外提供多用户服务需要另行满足 Google 验证、数据政策、隐私说明和安全评估要求。

验收：正确项目中能看到 API 已启用；客户端类型为 Web；回调完全一致；授权账号位于测试名单。控制台菜单名称会变化，以官方设置说明为准。[S1]

按需配置九类只读权限

在 Data Access 中选择 Google Health API 的 scopes；“readonly” 只限制上游写入，不保护你自己的网站。[S2]

完整 scope 由固定前缀加下表后缀构成。示例应用申请以下九类只读权限；如果不做路线、营养或特殊检查，建议同步缩小配置与代码的 SCOPES 列表。

所有后缀共用此前缀

https://www.googleapis.com/auth/googlehealth.

scope 后缀	用于
activity_and_fitness.readonly	活动、健身、运动会话
health_metrics_and_measurements.readonly	心率、HRV、血氧、测量记录等
sleep.readonly	睡眠与睡眠阶段
settings.readonly	设备、设置与同步相关信息
profile.readonly	个人资料
nutrition.readonly	饮食与饮水日志
location.readonly	运动 GPS 位置
ecg.readonly	心电图记录
irn.readonly	心律不齐通知

后续增加权限时

同时更新 Cloud 允许的 scopes 和服务端申请列表，重新发起同意授权。旧令牌不会因为你在控制台勾选了新权限就自动扩权。用户可能只授权部分范围，页面应按类别显示“缺少权限”，而不是把整个同步标为失败。

数据缺失依次核对：权限是否申请 → 用户是否授予 → 账号是否有记录 → 当前设备是否支持 → 时间过滤是否正确 → 代码是否实现该类型。

取得源码并完成基础安装

源码包只包含程序与教学配置，不带任何人的数据或登录态。

1. 上传并解压配套源码

先阅读源码包 README-教学说明.md，确认接受其单用户与安全限制。下面将源码上传到你自已创建的 SSH 别名 health-server；若没有别名，可替换为 ubuntu@自己的服务器。

本机 PowerShell：在下载目录执行

```
scp ./Air-Health-Tutorial-Source.zip health-server:~/  
ssh health-server
```

Linux：只用于新安装

```
mkdir -p ~/health-tutorial  
unzip -n ~/Air-Health-Tutorial-Source.zip -d ~/health-tutorial  
cd ~/health-tutorial/air-health-tutorial-source  
sudo bash install-base.sh  
sudo systemctl status air-health --no-pager
```

2. 明确安装脚本做了什么

创建专用 airhealth 系统用户；把代码安装到 /opt/air-health；把数据目录设为 /var/lib/air-health，权限 0700；安装主 systemd 服务，仅监听 127.0.0.1:8765。源码目录和运行数据分离。

没有自动做的事	原因
不覆盖已有安装	避免教程误覆盖读者已经在运行的健康网站。
不启用同步定时器	首次授权回填与定时增量不应同时竞争写入。
不安装 AI 或公网组件	先验证基础链路，再引入账号、模型和外部访问。

如果提示已有 /opt/air-health/app.py，请停止，不要删除目录重装。已有站点应先备份并制定升级方案。Ubuntu/Debian 以外发行版的包管理器和 nologin 路径可能不同。

主服务、目录和 SSH 隧道

位置	内容 / 权限
/opt/air-health	Python 代码、static 页面；root 管理，服务用户只读。
/var/lib/air-health	数据库、配置、令牌、原始归档、报告；仅 airhealth 访问。
/etc/systemd/system	服务单元；日志由 journal 与应用日志共同记录。

理解主服务的关键配置；完整单元已随包安装

```
[Service]
User=airhealth
Group=airhealth
WorkingDirectory=/opt/air-health
Environment=HEALTH_DATA_DIR=/var/lib/air-health
UMask=0077
ExecStart=/usr/bin/python3 /opt/air-health/app.py serve \
  --host 127.0.0.1 --port 8765
NoNewPrivileges=true
ProtectSystem=strict
ProtectHome=true
ReadWritePaths=/var/lib/air-health
```

本机 PowerShell：另开窗口执行，并保持连接

```
ssh -N -L 127.0.0.1:8765:127.0.0.1:8765 health-server
```

保持这个 SSH 窗口运行，在同一台电脑的浏览器打开 **http://localhost:8765/**。不要在手机上打开此 localhost 以完成电脑发起的 OAuth；手机的 localhost 指向手机自己。

Linux：检查监听边界和页面响应

```
ss -lnt | grep -E ':(8765|8766)'
curl -I http://127.0.0.1:8765/
```

验收：主服务为 active，监听 127.0.0.1；浏览器能打开配置页面。不要把 --host 改成 0.0.0.0，也不需要安全组向所有来源开放 8765。

完成第一次 Google 授权

整个授权过程使用同一浏览器、同一个 localhost 地址和同一条有效的 SSH 隧道。[S6]

操作步骤

- ① 在初始配置页面输入自己的 Client ID 与 Client Secret；确认回调为 `http://localhost:8765/oauth/callback`。先选择适度的历史回填范围。
- ② 保存并点击连接 Google；选择与手环数据关联的账号。
- ③ 核对应用名与权限列表后授权。若出现未验证提示，仅在确定这是自己的应用且测试账号正确时继续。
- ④ 返回面板后等待后台首次同步；“已连接”只代表授权成功，不代表每类数据已经下载完。

阶段	参考代码的行为
开始 /oauth/start	生成随机 state，服务端保存 10 分钟；请求 offline 授权。
Google 同意页	用户确认应用和 scopes；Google 返回短期授权 code。
回调 /oauth/callback	比对 state 和有效期；服务端用 code 交换令牌；清除 state。
后台查询	access token 过期前按需刷新；保留已有 refresh token。

凭据只放在服务器

config.json 保存 OAuth 客户端配置，token.json 保存授权令牌，写入采用受限权限。前端只拿业务数据。Google 密码不应输入自建面板；它只能输入 Google 官方登录页面。

Testing 状态的健康数据授权通常会遇到约 7 天的刷新令牌有效期。到期需要重新授权，不是 systemd 出故障。发布到 Production 也不代表令牌永不失效；撤销授权等情况仍会终止访问。[S1][S7]

首次同步后先比较少量记录：同一日期的步数、最近一晚睡眠和一条运动。未获得权限或没有记录的类别允许为空，不应出现伪造的“示例健康值”。

OAuth 常见错误，一次讲清

现象	判断和处理
403 access_denied：仅限测试人员	确认授权账号已加入正确项目的 Test users。项目管理员身份不一定代替测试用户身份。保存后从连接入口重新开始。
“此应用未经 Google 验证”	测试应用的提示，不等同于刚才的拒绝访问。仅在确认开发者就是自己、应用名与权限正确时继续。
redirect_uri_mismatch	逐字符比较协议、localhost/127.0.0.1、端口、路径和末尾斜杠；确认使用的是同一 OAuth Client。
OAuth state 校验失败	从面板重新连接；不要刷新旧 callback，不要复用截图里的地址。只保留一条授权流程，确认未超过 10 分钟。
invalid_grant / 连接失效	可能是过期、撤销、旧 code 被重复使用或客户端不匹配。确认本机时间后重新授权，不要反复修改 Secret。
回调 localhost 连接不上	检查 SSH 窗口是否仍运行、电脑 8765 是否被占用、授权是否跳到另一台设备。

为什么这个项目曾出现 state 失败

快照使用服务端单个 oauth_state 槽位。第二次点击连接会覆盖第一次发起的 state；旧标签页随后返回就无法匹配。它不只是 Cookie 问题，也不应通过“删除 state 检查”来修复。生产设计应把 state 绑定独立会话并做一次性消费。

日志怎么安全地看

只在自己的终端查看

```
sudo journalctl -u air-health -n 60 --no-pager
```

回调 URL 可能包含 code 和 state，错误日志也可能包含敏感查询。分享时只摘取错误码、发生环节和已脱敏信息；不要截图整个地址栏。不要在日志中打印 token 响应。

同步接口：日汇总与原始记录

本项目调用 v4；旧 Fitbit API 的路径、过滤字段、权限不能直接套过来。[S4][S5]

目标	操作模式
已结束日期	对支持的类型调用 dataPoints:dailyRollUp，按自然日汇总。
日级健康指标	按日期读取 / reconcile，如 daily-resting-heart-rate、daily-heart-rate-variability。
当天和运动细节	读取原始 / reconcile 时间序列，再在本地构建快照或截取运动时间窗。
睡眠与运动会话	查询 sleep / exercise，保留会话范围、摘要和可用的分期、路线关联。

解释性示例：实际参数用 URL 编码，日期需换成自己的记录日期

```
GET /v4/users/me/dataTypes/heart-rate/dataPoints:reconcile
filter=heart_rate.sample_time.civil_time >= "2026-01-01"
AND heart_rate.sample_time.civil_time < "2026-01-02"
dataSourceFamily=users/me/dataSourceFamilies/all-sources
pageSize=1000
```

路径里是 heart-rate，过滤字段里是 heart_rate；过滤范围用 **包含起点、不包含终点**。用 URL 编码传递参数。Civil time 与 physical time 不能混合；睡眠常按结束时间筛选。具体类型的支持操作与限制不同。[S4]

分页与容错

读取 dataPoints，若有 nextPageToken 就继续请求；某类数据失败时记录该类别错误并继续其他类别。401 可尝试刷新一次；429 和暂时性 5xx 用有限次数退避重试。建议在快照基础上补充 Retry-After、随机抖动与请求预算。

不要对所有数据类型套同一个 365 天请求。当前代码按类型分块，有 14 天、90 天或逐日归档等实现策略；它们不是所有接口统一的官方上限。ECG 等特殊类型须单独核对过滤规则。

为什么看到的是昨天的数据

这不是一个“把页面日期改成今天”就能解决的问题。

事件	含义	界面应展示
设备记录 07:10	手环最后产生样本的时刻	数据截至 07:10
手机上传 07:18	上传到 Google 的时刻	设备最后同步时间
服务拉取 07:22	网页后台完成查询的时刻	后台同步完成时间
夜间指标次日形成	不是实时心率或实时 HRV	最近一晚 + 实际日期

上表时刻为虚构演示，不是任何人的活动记录。

本项目的处理方式

已完成日期使用日汇总；当天不等待完整日聚合，而从原始 reconcile 记录重建当天活动快照。最新样本心率、静息心率、夜间 HRV 分开呈现，不用一个“今天”标签混在一起。

逐层检查

1. 手机官方应用是否已经出现最新记录？如果没有，先完成设备同步。
2. 网页后台同步是否成功？留意每类接口的错误或缺少权限。
3. 页面显示的到底是“数据截至时间”还是“查询时间”？
4. 记录时间是否转换到用户时区？跨午夜运动、睡眠应有一致归属规则。
5. 是否把缓存中昨天的快照误当成今日实时值？

必须正视的两个限制

数据源口径：快照部分日汇总使用 google-wearables，而原始数据使用 all-sources，可能因为手动记录或其他来源产生差异。生产版应统一口径或明确标识。

晚到数据：已存在的历史原始归档可能被跳过；需要受控地重新抓取相关日期，不能永远把“文件存在”当作数据已最终完整。

界面至少显示三个状态：真实 0、暂缺数据、同步失败。不要用当前时间掩盖旧数据，也不要把“未查询到”自动解释为“当天没有活动”。

存储设计与数据质量

文件 / 目录	内容	是否适合分享
health.db	SQLite 日指标、会话、状态与分析缓存	否
raw-archive/	高频原始记录的按日 gzip JSONL	否
routes/	关联运动路线或轨迹数据	否，可能暴露住址
reports/	日报、周报及 AI 解读归档	否，仍是健康数据
config.json / token.json	客户端配置与 Google 授权	绝不能公开
backups/	数据库与归档的压缩备份	否，压缩不等于加密

单位与派生指标必须可解释

距离、海拔等原始字段可能用毫米；时长可能由区间计算，热量区分活动消耗与总消耗。参考代码把距离转成公里、海拔转成米。每个派生指标应记录来源字段、换算公式、时间范围和缺失情况，而不只存一个数值。

缺失、重复与覆盖

用稳定记录标识或可重复计算的键做更新，避免每次同步都累加同一天。保留被更正记录的更新时间；同一指标来自不同设备时，明确合并策略。展示有效天数、样本数与可用比例，比较周总量时检查两周覆盖是否相当。

规模与同步锁

高频心率和路线增长比日汇总快，定期查看磁盘。压缩原始数据可以减少占用，但索引、解压和备份成本仍存在。当前锁是进程内锁：Web 后台线程和 systemd 单独进程并不共享，正式运行建议统一任务队列或给所有写入口加同一跨进程锁。

不要直接修改 SQLite 来“修正页面”。先明确上游原始记录，再修复转换逻辑、回填受影响日期，并保留可回滚的备份。

页面组织：从单页到信息中心

每个页面回答一个问题，而不是把所有可读取字段堆成一张长表。

页面	优先表达的信息
总览	今日活动、最近一晚恢复、关键指标、数据截至时间与待处理问题。
活动与训练	训练频率、周时长、活动热量、强度分布、运动列表与详情。
睡眠与恢复	睡眠时长/规律性、分期、静息心率、HRV 及自己的近期基线。
心脏与健康	心率、血氧、呼吸率、温度、体测；特殊记录单独处理。
趋势探索	可选指标、时间跨度、同轴对照或散点相关性、覆盖率。
健康周报	完整周期、与上周对比、亮点、需要留意、下一周可执行事项。
AI 分析 / 自由问答	健康上下文分析与不带健康上下文的聊天分开；明确上传和模型选项。

图表表达规则

趋势折线适合连续日期；柱状图适合活动量；睡眠分期用时间轴，比例用环形图；强度结构用分区条；指标相关性用散点图。缺失值留空，不连成伪造轨迹，不画一条虚构的“正常曲线”。

先保证数字语义，再追求视觉效果

今天尚未结束，不直接与完整一天比较总量。静息心率不等于当前心率；HRV 算法和采样条件不同，不能跨平台机械比较。恢复分数、训练负荷和相关性属于本地派生解释，应给出算法说明与限制。

验收：任意一个主卡片都能回答“哪一天、什么单位、来自哪里、有多少有效数据”。没有数据时展示原因，而不是演示数据。

运动详情：心率图与训练解读

从运动列表点进去

在“活动与训练”中选择一条会话，展开详情。优先显示运动类型、实际起止时间、有效时长、距离、消耗热量、平均与最高心率；只有来源提供时才显示配速、步频、圈段、海拔或路线。不要把不存在的字段补成 0。

图表	用途与实现注意点
运动心率折线	按会话时间窗截取样本；横轴为经过时间，纵轴 bpm。标出缺测区间；不要把整天最高心率当成运动峰值。
心率区间分布	显示各区间时长及占比。区间边界优先使用用户/设备返回值，不把通用公式当成个人医学阈值。
阶段或圈段对比	比较不同片段的时间、配速、心率反应；聚合策略需要说明。
同类历史对比	同运动类型、相近时长/距离下比较，排除覆盖率过低记录。
周训练结构	运动时长、频率与恢复间隔；负荷变化只是启发式，不等于受伤概率预测。

AI 单次运动分析的输入

给模型会话摘要、心率统计、强度分布、数据覆盖率和少量同类历史。输出顺序建议固定为：客观观察 → 可能解释 → 数据不足 → 下一次可尝试的调整。默认不发送逐点心率或精确 GPS。

腕式传感器可能因佩戴、运动方式和信号质量出现误差。AI 不应根据一条运动曲线诊断心脏病，也不应在缺乏症状、既往史和专业评估时给出激进训练处方。

测试用虚构会话覆盖：没有心率、只有一个样本、跨午夜、暂停很长、缺少距离、极短运动。图表降级应清晰，不崩溃、不捏造。

手机端布局与交互验收

小屏幕的关键不是把桌面页面整体缩小，而是重新安排信息优先级。

布局原则

页头只保留站点名、简短同步状态和主操作；减少重复欢迎语的高度。让最重要的 2 至 4 个指标优先出现。窄屏卡片采用紧凑网格，复杂图表单列，详细解释按需展开。

导航与长内容

横向标签必须有可发现的滚动提示，当前标签可见；吸顶导航不遮挡内容。长周报和 AI 回答默认摘要、支持展开。表格只在表格容器内横向滚动，避免整页左右滑动。

理解响应式布局；配套项目已有 `mobile.css`，不要重复粘贴覆盖

```
<meta name="viewport"
      content="width=device-width, initial-scale=1">

/* Example only: adapt to the existing class names. */
@media (max-width: 600px) {
  .metric-grid { display: grid;
    grid-template-columns: repeat(2, minmax(0, 1fr)); }
  .detail-panel { width: 100%; max-height: 90dvh;
    overflow-y: auto; }
  .chart-wrap { min-width: 0; overflow-x: auto; }
}
```

场景	验收
360 / 390 / 430 px 宽度	文字不被截断，按钮可点，无整页横向溢出。
周报浅底卡片	不能沿用深色背景中的白色标题；对比度足够。
软键盘与图片上传	输入框不被遮挡；预览可移除；发送状态与错误清楚。
运动弹层 / 返回	可关闭、可滚动、关闭后回到原列表位置。

最终必须用真实手机浏览器测试。桌面模拟宽度能发现布局问题，但不能覆盖地址栏伸缩、键盘、安全区和触摸行为。

公网之前，先安装登录网关

浏览器可直接打开 ≠ 所有人都能看到。公网流量必须先经过身份检查。

参考项目用 web_gateway.py 将已登录请求转发到主服务。未登录访问 /api/* 返回 401；管理配置和 OAuth 路由不在公网允许列表。Cookie 设置 Secure、HttpOnly 和 SameSite=Strict，因此真正登录请使用 HTTPS。

Linux：网关初次配置；工具不回显密码，拒绝覆盖已有配置

```
cd ~/health-tutorial/air-health-tutorial-source
sudo python3 configure-web.py
sudo install -m 0644 air-health-web-gateway.service \
/etc/systemd/system/
sudo systemctl daemon-reload
sudo systemctl enable --now air-health-web-gateway
curl -i http://127.0.0.1:8766/api/status
```

配置工具将用户名设为 healthdemo。请在密码管理器生成唯一的长随机密码并输入，至少 24 个字符。程序只保存密码摘要和随机会话密钥到 /etc/air-health-web.env，root 所有、0600 权限。

验收项	预期
网关监听	仅 127.0.0.1:8766；主应用仍是 127.0.0.1:8765。
未登录 API 请求	401，不泄露健康指标、设备信息或同步详情。
未登录首页	可以返回登录页 200；200 不代表数据已公开，也不证明已登录。
登录后的管理路由	/api/setup、/oauth/start 等仍不可从公网操作。

这是个人实验网关，不是完整身份平台。快照使用单一密码 SHA-256 摘要、内存限流和签名会话。正式对外使用应采用成熟身份系统、强认证、可靠限流与完整 CSRF 防护，并进行安全审查。

即使有密码，也不要公开分享自己的站点地址。只读 Google scope 不限制别人读取你已经下载到 SQLite 的数据。

通过 HTTPS 在手机上访问

临时演示：Quick Tunnel

先按 Cloudflare 官方说明安装适配服务器架构的 cloudflared，核对来源与版本，再启动下面的命令。只代理 8766 登录网关，不要代理 8765 主应用。[S8]

Linux：先前台验证；出现的随机 HTTPS URL 是你自己的临时入口

```
cloudflared --version
cloudflared tunnel --no-autoupdate --protocol http2 \
  --url http://127.0.0.1:8766
```

在手机浏览器打开命令输出的 HTTPS 地址，先看到登录页，输入自己设置的账号密码后才能查看数据。首次 Google OAuth 仍在电脑 SSH 隧道内完成，不需要把随机公网域名加入原回调。

临时隧道需要长期后台运行时

先核对单元中 cloudflared 的绝对路径、用户和 HOME 目录存在

```
command -v cloudflared
sudo install -d -o airhealth -g airhealth -m 0700 \
  /var/lib/airhealth-tunnel
sudo install -m 0644 air-health-tunnel.service \
  /etc/systemd/system/
sudo systemctl daemon-reload
sudo systemctl enable --now air-health-tunnel
sudo journalctl -u air-health-tunnel -n 30 --no-pager
```

配套单元预期 /usr/local/bin/cloudflared，并使用 /var/lib/airhealth-tunnel 作为 HOME。首次使用时创建该目录并让 airhealth 所有；若官方安装路径不同，应编辑单元而不是复制来源不明的可执行文件。

正式地址：命名隧道或自有反向代理

Quick Tunnel 用于演示，随机地址可能变化，且有并发与 SSE 等限制。长期使用应配置自己域名下的命名隧道或维护 HTTPS 反向代理，并增加身份访问策略。域名、TLS、会话和 Google OAuth 回调是不同配置项。[S8]

不要假设“部署在服务器上”就能保证所有网络或地区访问。AI 流式 SSE 也不能在未确认隧道能力时直接启用。向外求助时隐藏临时 URL 和登录信息。

AI 分析：先划清数据边界

这里是自建应用调用模型，不是把 ChatGPT 官网嵌入网页，也不是无限使用 ChatGPT。

层级	提供什么	不应做什么
本地规则	趋势统计、覆盖率、训练结构、可解释的提示	把启发式恢复分数当作临床评分。
模型解读	总结趋势、解释可能原因、生成可执行的回顾	补造未测量值、做诊断、修改药物。
自由问答	文字对话、选择可用模型、解释用户上传图片	默认附加整份健康数据库或 GPS。

推荐的隔离结构

主应用用 airhealth 运行，能读 Google 令牌和健康数据；AI broker 用另一用户 airhealth-ai 运行，只从受限 Unix socket 接受文本摘要与显式上传图片。Google 数据目录 0700，AI 用户不能直接读取。

健康分析默认发送聚合指标和真实日期范围；运动分析发送本次统计与有限历史。自由问答默认不带健康数据，只有用户明确开启相应选项才附带摘要。模型收到的内容依然是个人数据，不能因为“聚合”就声称完全匿名。

AI 的提示词合同

输出结构示例；业务层仍需校验，不能只依靠提示词

INPUT: dated aggregates, sample counts, data freshness

OUTPUT:

- 1. Observed facts with dates
- 2. Possible explanations, not diagnoses
- 3. Missing data and uncertainty
- 4. Small, realistic next steps

NEVER: invent measurements, expose secrets, alter medication

read-only 沙箱不等于“完全无工具”；ephemeral 也不等于“模型供应商不保存数据”。需要独立用户、文件权限、网络边界、数据最小化与上游隐私设置一起生效。[S11]

为降低出错和费用：按需生成、限制摘要长度、限制并发与超时、缓存带版本结果，并保留无 AI 时可用的规则报告。

可选：部署 Codex AI broker

必须使用读者自己的账号和当前可用版本，不附带任何登录缓存。[S9][S10]

1. 准备独立运行用户和官方 CLI

新安装示例；用户已存在时先核对，不重复创建

```
sudo useradd --system --gid airhealth \
  --home-dir /var/lib/air-health-ai \
  --shell /usr/sbin/nologin airhealth-ai
sudo install -d -o airhealth-ai -g airhealth -m 0700 \
  /var/lib/air-health-ai
sudo install -d -o root -g root -m 0755 \
  /var/empty/air-health-ai /usr/local/libexec
codex --version
codex exec --help
```

先按官方步骤安装完整 Codex CLI 及依赖，再执行上面的版本检查。确保系统用户可执行，不能只拷贝一个二进制丢掉配套运行文件。快照 broker 调用 `/usr/local/libexec/air-health-codex`；不要指向管理员私有 `home` 下的安装。

2. 为 AI 用户单独登录并验证

设备码方式需要账号允许；只在官方登录页输入临时代码

```
# Only if this is the verified installation path:
sudo ln -s /usr/local/bin/codex /usr/local/libexec/air-health-codex
sudo -u airhealth-ai -H codex login --device-auth
sudo -u airhealth-ai -H codex exec --ephemeral \
  --sandbox read-only --skip-git-repo-check \
  -C /var/empty/air-health-ai -- "Reply with OK only."
sudo install -m 0644 air-health-ai.service /etc/systemd/system/
sudo systemctl daemon-reload
sudo systemctl enable --now air-health-ai
```

上方链接命令假设已确认 CLI 位于 `/usr/local/bin/codex`；路径不同请替换，目标入口已有时不要强制覆盖。核对 `/run/air-health-ai/agent.sock` 仅服务用户/组可连接。先用不含健康数据的“回复 OK”测试，成功后再试精简健康分析。

版本兼容检查不能跳过。 快照含 `--ignore-user-config` 等参数和历史模型白名单。若当前 CLI 不支持，先设计等价的配置隔离并修改调用；不要简单关闭沙箱或扩大目录权限来让它“能跑”。可用模型与费用以读者实际账号为准。

自由问答、模型选择和图片

用户怎样使用

打开自由问答标签页，输入问题；可选模型后发送。上传图片时先检查预览，确认没有身份证、姓名、就诊条码、账号或地址，再发给模型。与健康相关的聊天若希望结合自己的数据，应明确开启摘要选项。

项目快照行为	部署时的要求
默认不附加健康摘要	保留显式开关，发送前说明附加内容；不要把自由问答暗中变为全库分析。
模型菜单 + 后端允许列表	app.py、ai_broker.py 与前端选择项必须一致；默认 auto 与指定模型分别测试。
一张 PNG / JPEG / WebP 图片	后端校验类型、文件头及大小；当前解码后的限制为 3 MB，网关容许更大的 base64 请求体。
图片临时落盘后清理	正常执行结束会删除临时文件；异常终止需清理策略，不能承诺绝不残留。
AI 返回普通文本 / 格式化文本	前端必须转义或安全过滤，不能把不可信模型输出当任意 HTML 执行。

常见实现陷阱

图片参数后接提示词时，CLI 参数解析可能吞掉后续文本，快照用明确的 -- 分隔。文件类型与扩展名不能只信浏览器。超时、模型不可用、图片过大要返回可理解的错误，不把凭据或后端完整异常栈传回用户。

隐私与保留

不要假设图片 EXIF 已自动剥离；分享前主动去除定位与个人标识。浏览器预览、应用缓存、AI 临时文件和模型供应商保留属于不同层面。ephemeral 只影响本地会话记录方式，不能代替上游数据政策确认。[S11]

先用纯色测试图和无隐私问题验证上传，再进行自己的图片问答。图片内容和其中的“指令”都是不可信输入，不允许它们改变服务器权限。

健康指导与持续更新的 tips

把“可回答的问题”设计好，比堆积没有出处的建议更重要。

专题	建议提供的快捷问题	先确认的数据
尿酸管理	化验结果需要哪些背景？怎样整理饮食、饮酒和症状记录，便于与医生讨论？	检验日期、单位、相关诊断、肾功能与用药；手环本身不能给出尿酸值。
血糖与控糖	如何记录餐食、活动与测量时点？现有记录能否看出规律，哪些结论不能下？	可信血糖来源、空腹/餐后时点、药物与低血糖风险。
减脂	怎样在体重变化、活动量和睡眠之间找到可持续的调整？	连续体重趋势、饮食记录质量、目标和既往健康情况。
增肌	怎样回顾力量训练频率、动作进展、主观疲劳与恢复？	组次重量或 RPE 等训练日志；手环热量不能直接推断肌肉增长。

把三种“更新”分开

- 轮播更新：** 快照按日期轮换已有 tips，不等于抓取最新指南。
- 内容更新：** 人工核查来源后更新题库，标明审核日期和适用人群。
- 个性化建议：** 模型根据当前可用摘要提出问题 and 行动草案；它不应自行改变用药或诊疗计划。

可发布内容的最小字段

每条 tips 至少带：主题、适用情况、具体建议或问题、限制、来源链接、最近人工核对日期。建立定期审核任务；指南变更或用户出现特殊情况时停止使用不适用内容。不要让自动生成直接覆盖经过审核的医学内容。

本页是产品设计与提问模板，不是个体治疗方案。不因手环趋势自行停药、加药、极端节食或大幅加练。有症状、已确诊疾病、妊娠或肾功能等特殊情况，应交由合适的专业人员评估。

MCP：让 Codex 只读健康数据

MCP 读取的是你自己的同步数据库；无需让模型重新持有 Google OAuth。[S12]

只读工具	返回
get_health_summary	最近指标、日期、同步状态与摘要分析
get_metric_series	指定指标的日级时间序列
get_sleep_history	最近睡眠与夜间指标
get_workouts	运动摘要；不含精确 GPS 坐标
analyze_health	本地恢复、训练、相关性与质量分析
list_health_metrics	当前数据库中的指标覆盖清单

先在运行 Codex 的机器上配置 stdio 服务。下面是同服务器配置结构：需要管理员预先为该用户授权**这一条精确只读启动命令**，否则 `sudo -n` 会失败。不要给通用免密 `sudo`。

在该 Codex 实例实际使用的 `config.toml` 中添加；不要覆盖原配置

```
[mcp_servers.google_health]
command = "sudo"
args = ["-n", "-u", "airhealth", "/usr/bin/env",
        "HEALTH_DATA_DIR=/var/lib/air-health",
        "/usr/bin/python3", "/opt/air-health/mcp_server.py"]
```

电脑上的 Codex 若要读远程库，可将 `command` 换成 `ssh`，通过已验证主机密钥的 `health-server` 执行同一启动命令；确保远程 `stdout` 只有协议 JSON，日志进入 `stderr`。不要把 `stdio` 当 HTTP 服务直接公开到互联网。

验证与隔离

重启或刷新 MCP 配置，先调用 `list_health_metrics`，再请求少量指定日期的序列，核对返回实际日期。当前实现使用只读 SQLite 连接和固定工具，不提供任意 SQL，但并非完整多租户授权系统。更强隔离可向单独用户提供脱敏只读快照，而非授予原始数据目录权限。

`readOnlyHint` 只是工具声明，不是安全边界。调用结果会进入模型上下文，仍是个人健康信息；不要接入与本任务无关的共享会话或第三方代理。

健康周报：完整周期与可追溯结论

一份可靠周报应包含什么

周期起止日期、使用时区、各指标有效天数、活动总量、睡眠均值、夜间指标、运动清单、与前一等长周期对比、数据不足说明，以及下一周少量可执行事项。AI 叙述之外保留机器可复核的数值与来源。

当前快照	如何理解
核心周指标	步数、距离、活动热量、运动时长、睡眠、HRV、静息心率、血氧、呼吸率与久坐。
规则解读 + 可选 AI	AI 失败仍保存规则报告；不能让整个周报消失。
命令 <code>weekly-report</code>	以昨天为结束日，向前取 7 天；周一运行时对应上一完整自然周。
网页即时周报	可能是截至当前日期的滚动窗口；它与已归档完整周报需要明确区分。
JSON 归档	保存到 <code>reports/</code> ，带生成时间与周期；历史结果不应被新模型静默覆盖。

手动验证一次；非周一执行时，结果不是上一完整自然周

```
sudo -u airhealth env HEALTH_DATA_DIR=/var/lib/air-health \  
python3 /opt/air-health/app.py weekly-report
```

不能过度解读的比较

两周记录天数不同，不直接根据总量百分比断言进步或退步；基线为 0 时不给无穷百分比。数据缺失不能当成真实零。快照中部分规则和求和行为仍需生产化校正，运动条数也有上限，不能宣称覆盖了账号所有历史训练。

营养、体测、路线、ECG 等“已同步”不代表“已自动纳入周报”。扩展周报时逐类定义汇总规则；心电图和检验值更适合列出事实与待确认问题，不自动下诊断。

定时任务：同步、日报与周报

这些是服务器的 systemd 任务，不依赖你的电脑或 Codex 桌面一直打开。

任务	快照计划	关键点
同步 sync	每 30 分钟，随机延迟至多 3 分钟	增量近 2 天；首次回填未完成时先不要启用。
日报 daily-brief	每天 08:20，至多 5 分钟延迟	与同步完成时间错开；按当前数据日期解释。
周报 weekly-report	周一 08:10，至多 10 分钟延迟	正常生成上一完整周；延后运行仍核对周期。
备份 backup	每天 03:40，至多 10 分钟延迟	保持独立与可验证；不要与大型回填挤占磁盘。

日报、周报和备份单元显式使用 Asia/Hong_Kong 的计划；同步计划跟随系统时区。应用部分日期逻辑依赖系统本地日期，建议服务器与用户的报表时区一致，或明确修正代码，避免午夜偏移。

确认首次同步结束、AI 已按需配置后，选择性启用任务

```
cd ~/health-tutorial/air-health-tutorial-source
sudo install -m 0644 air-health-sync.service \
  air-health-sync.timer air-health-daily-brief.service \
  air-health-daily-brief.timer air-health-weekly-report.service \
  air-health-weekly-report.timer air-health-backup.service \
  air-health-backup.timer /etc/systemd/system/
sudo systemctl daemon-reload
sudo systemctl enable --now air-health-sync.timer \
  air-health-daily-brief.timer air-health-weekly-report.timer \
  air-health-backup.timer
systemctl list-timers 'air-health-*' --all
```

Persistent=true 会在停机后补触发错过的任务，但不等于自动生成所有漏掉的历史周报。不要同时再写一套 cron 或应用定时循环，否则容易重复生成、重复调用模型或并发同步。

当前同步锁不跨进程。稳定运行前应让手动、网页和定时入口进入同一队列或统一文件锁；在未补强版本中，避免在定时同步期间重复点击同步。监控失败时通知，不要把整份健康周报发到公开通知渠道。

备份与恢复：数据不能只存一份

创建并验证应用备份；默认管理最近 14 份，先确认保留策略

```
sudo -u airhealth env HEALTH_DATA_DIR=/var/lib/air-health \  
python3 /opt/air-health/app.py backup  
sudo -u airhealth env HEALTH_DATA_DIR=/var/lib/air-health \  
python3 /opt/air-health/app.py backup-verify
```

快照在读事务中导出数据库并重建一致副本，再执行完整性检查和哈希核验。压缩包包含 database/health.db、manifest.json 与存在的 raw-archive、routes、reports；不包含 token.json、config.json、日志或备份自身。
[S14]

不含令牌仍然不是匿名备份。 数据库、路线和 AI 周报可能高度敏感；gzip 不加密。异地副本需要可靠加密和独立密钥保管。数据库一致不代表同时复制的所有原始目录是同一瞬间快照，关键迁移宜暂停写入。

恢复演练：先检查，后切换

1. 选定自己的备份文件，执行校验；在新的私有临时目录列出并检查成员，不接受绝对路径、父目录穿越或不可信链接。只处理自己生成且已验证的备份。
2. 把 database/health.db、raw-archive、routes、reports 解压到隔离测试目录，检查表数量、日期范围与 JSON 解析。
3. 暂停所有写入：主应用、同步、日报、周报、备份任务及其定时器。确认没有正在运行的同步进程。
4. 先将当前数据目录整体移到一个明确、受限权限的回滚目录；创建新的数据目录，再放入已验证恢复内容，保持 airhealth 所有与 0700/0600 权限。
5. 凭据没有包含在备份中：保留自己的有效配置/令牌，或重新进行 Google OAuth。不要把别人的授权文件拷进来。
6. 先只启动主应用，通过 SSH 隧道核对日期、记录数量与图表；确认无误再恢复网关、同步和其他定时器。
7. 验收失败则停止写入，回切之前保留的目录；不要直接覆盖唯一的旧副本。

这里故意不给一条递归删除命令：备份文件名、目标目录和当前服务状态各不相同。真正恢复前记录明确路径并逐步确认，不能机械粘贴一串覆盖命令。

系统排障：沿数据链逐层定位

症状	优先检查	不要做
全站空白 / 502	主服务与网关状态、上游端口、静态资源路径	直接放开所有端口。
授权成功但全无数据	账号是否关联设备、首次同步是否结束、API 错误、过滤日期	把 “connected” 当同步完成。
只有部分指标	每类 scope、设备支持、源记录、接口字段及分页	把空白写成 0 或假数据。
一直显示正在同步	日志是否前进、429/超时、大回填、进程是否中断	无限制重试或连续点击。
AI 无响应	独立账号登录、socket 权限、CLI 路径、参数、模型、上游连通性	复制管理员凭据或关闭隔离。
图片能选不能发	MIME/文件头、3 MB 限制、base64 体积、代理超时	只提高前端限制。
MCP 启动失败	配置在哪台机器、精确执行权限、数据库权限、stdout 是否被日志污染	公开数据库或授予任意 sudo。
周报日期不对	系统时区、自然周/滚动窗口、补触发时刻	只改标题日期。

只读诊断；日志不应原样上传到公开平台

```
systemctl --failed
systemctl status air-health air-health-web-gateway --no-pager
journalctl -u air-health -n 80 --no-pager
journalctl -u air-health-ai -n 40 --no-pager
df -h /var/lib/air-health
ss -lnt
```

报错求助模板：发生环节、错误码、软件版本、已脱敏请求结构、预期与实际现象。不要带 Authorization、Cookie、OAuth 回调完整 URL、登录缓存或真实健康响应。

隐私与安全：上线前的硬检查

保护对象	最低措施
Google 凭据	只在服务端；专用用户和目录；撤销时清理令牌；不要打印或打包。
健康与 GPS	私有存储、最小访问权限、敏感路线不外传；备份同级保护。
公网网页	HTTPS、登录、限流、受限路由；后端端口仅 loopback。
AI 登录态	单独用户、受限 home；不复用全权限个人工作区；没有无关 MCP。
用户输入和输出	限制大小、校验字段、转义输出、拒绝任意路径/命令、保护请求来源。
维护与日志	可靠更新、定期复核权限、最少日志、定期恢复演练。

分享教程或仓库时：白名单导出

只导出明确允许的源码、脱敏说明和示意图。排除 data、数据库、原始归档、routes、reports、backups、.env、config.json、token.json、.codex、截图和日志。不要“整目录打包后再凭记忆删几个文件”。

图片和元数据也属于隐私面

浏览器地址栏、头像、邮箱、项目名、设备同步时间、真实曲线、运动路线、二维码、文件名、PDF 作者和图片 EXIF 都需要检查。本 PDF 使用重绘架构与虚构时间，没有复用原始账号或健康截图。

泄露后的处理顺序

先限制入口并停止继续传播；按影响范围撤销 Google 授权、轮换客户端密钥或网站密码/会话密钥、撤销 AI 登录态；保留必要审计信息；确认缓存和备份的暴露范围。单纯从截图上打码，不能使已经泄露的令牌重新安全。

快照尚未经过独立安全审计。面向其他真实用户开放之前，应改造多用户隔离、OAuth 会话绑定、统一任务锁、完整认证和数据删除机制，不能把单用户示例直接升级为公共医疗产品。

扩展方向与开源项目借鉴

先补数据可信度和安全基础，再增加更“聪明”的功能。

从 openfit 学习什么

openfit 将 Fitbit 数据看板和 Codex 助手结合，是页面与交互思路的参考。它定位于桌面应用，本教程是服务器网页部署，不能把它的安装方式或权限模型照搬。复制代码前核对许可证、依赖和提交版本；不要用 Star 数量代替质量或安全判断。[S13]

优先级	值得增加的功能	验收依据
P0	统一时区、数据源口径、空值语义、晚到数据回填、跨进程锁	同日期数据可对账；中断/重复同步不重复记账。
P0	身份保护、上传清理、令牌撤销、审计与恢复	未登录取不到数据；恢复演练通过。
P1	运动对比、睡眠规律性、覆盖率与置信提示	图表可追溯到具体样本和统计范围。
P1	周报扩展营养/体测、训练日志与主观疲劳	明确哪些来自手环、手工记录或模型推断。
P2	带来源与审核日期的 tips 库、健康问答路由	内容可复核，过期建议可撤下。
P2	长期趋势、目标回顾、可控通知、私有导出	最小披露，不把报告自动发到不可信渠道。

如何验证 AI 优化真的有用

用同一份虚构数据构造缺失、冲突、异常与正常变化场景；比较模型是否注明日期、引用事实、表达不确定性和避免医疗越界。记录模型、提示词版本、数据版本与生成时间。用可复核测试替代“回答听起来很专业”。

不要直接在真实数据库上试验新图表、新 SQL 或新模型提示词。先在无个人信息的合成样例中验证，再对自己的数据做受控只读测试。

最终验收与维护节奏

阶段	通过标准
Cloud / OAuth	正确 API、正确回调、自己的测试账号、授权 scopes 可核对；扩权要重授权。
服务	重启后自动恢复；只监听 loopback；配置与数据不在静态目录。
同步	日汇总和当天快照区分；显示真实日期；分页完整；缺失不伪装为零。
运动 / 手机	详情字段可追溯；心率图有单位和缺测提示；窄屏无整页溢出。
公网	未登录 API 返回 401；HTTPS 登录正常；OAuth/配置入口不公开。
AI / 图片	无健康摘要时不发送；模型实际可用；上传校验通过；解释不越界。
MCP	只读工具可用；stdout 协议正确；未开放公网、任意 SQL 或宽泛 sudo。
周报 / 备份	周期明确、覆盖率正确、AI 失败可降级；备份校验和恢复演练通过。
对外分享	只含脱敏源码、示例与文档；不含任何运行时数据、凭据或私人截图。

建议维护节奏

- 日常：** 查看同步是否真正推进、磁盘是否充足、登录和任务是否异常。
- 每周：** 核对周报覆盖率和备份验证，检查一条原始记录到图表的完整映射。
- 定期：** 查看官方 API / CLI 变更，审核模型允许列表、医疗内容来源和数据保留策略。升级前备份，升级后重复上述验收。

当你能解释每一条数据的来源、日期、权限和去向，并且能从备份恢复它，才算真正完成“从手环到私有健康网站”的部署，而不只是有了一个能打开的网页。

参考资料 1 / Google Health

正文中的 [S编号] 可点击跳转到这里；下方网址均为可点击链接。

[S1] Google: 设置 Cloud 与 OAuth

<https://developers.google.com/health/setup>

项目、测试用户、权限、刷新令牌及可选的 RISC。本文的回调地址来自参考应用，而非照搬官方 Playground 示例。

[S2] Google: Google Health OAuth scopes

<https://developers.google.com/health/scopes>

只读权限及数据类别。按实际功能申请，不把“已勾选权限”等同于“已经获得数据”。

[S3] Google: Health API 数据类型

<https://developers.google.com/health/data-types>

确认各类型的字段、可用操作和设备支持；新增类型不一定已被本教程快照实现。

[S4] Google: 数据过滤规则

<https://developers.google.com/health/filters>

路径与过滤字段命名、时间边界和数据源族。具体 API 参数以该页和 Reference 为准。

[S5] Google: Fitbit API 迁移规范

<https://developers.google.com/health/migration/api-specifications>

用于理解 Google Health 与旧 Fitbit Web API 的差异；不能直接复用旧授权或旧响应结构。

[S6] Google: Web Server OAuth 2.0

<https://developers.google.com/identity/protocols/oauth2/web-server>

服务端授权码流程、离线访问及重定向 URI。实现 OAuth 前的基础阅读。

[S7] Google: OAuth 应用受众与发布

<https://support.google.com/cloud/answer/15549945?hl=en>

确认 Testing、测试用户和发布状态的影响；上线要求会随应用用途和权限变化。

阅读时间：2026-09-08。教程操作来自项目实践，接口能力和发布要求以官方当时适用条款为准。官方 UI 或文档变化时，不应机械照搬旧截图。

参考资料 2 / 部署与 AI

优先使用官方 CLI 和文档；开源项目作为学习参考，不代表可直接安全上线。

[S8] Cloudflare: Quick Tunnels

<https://developers.cloudflare.com/cloudflare-one/networks/connectors/cloudflare-tunnel/do-more-with-tunnels/trycloudflare/>

临时公网入口的用途和限制；不应把随机子域名当作访问密码或稳定生产地址。

[S9] OpenAI: Codex CLI

<https://developers.openai.com/codex/cli>

使用官方完整安装方式。入口可能跳转至 ChatGPT Learn；模型及功能以安装版本为准。

[S10] OpenAI: 身份验证

<https://developers.openai.com/codex/auth>

远程登录、设备码流程和凭据存储。AI 账号授权与 Google Health OAuth 是两套独立机制。

[S11] OpenAI: 非交互执行

<https://developers.openai.com/codex/noninteractive>

codex exec、输出、ephemeral 与沙箱。临时会话不代表上游零保留，也不是医疗安全保证。

[S12] OpenAI: Codex 中的 MCP

<https://developers.openai.com/codex/mcp>

stdio 命令、参数和配置结构。自建 MCP 仍需完成本地权限与数据最小化设计。

[S13] FlavioAdamo / openfit

<https://github.com/FlavioAdamo/openfit>

桌面 Fitbit 看板与 Codex 助手的参考项目。本教程借鉴功能组织思路，不宣称本项目是其官方分支。

[S14] Python: sqlite3 文档

<https://docs.python.org/3/library/sqlite3.html>

理解事务、只读连接与一致性备份；不要随意复制正在写入的数据库文件。

来源说明：本文为原创组织与项目实践总结，未复刻官方页面截图或他人健康记录。图示为重新绘制；个人账号、真实服务域名、设备标识与运行日志未纳入交付。

参考资料 3 / 免费云服务器

免费资格、额度和价格会变化；提交创建和升级前请重新核对。

[S15] Google Cloud：免费计划与试用

<https://docs.cloud.google.com/free/docs/free-cloud-features>

Free Trial 与持续 Free Tier 的区别；Compute Engine 的机型、地区、时长、标准磁盘和流量额度。

[S16] Google Cloud：网络与 IP 定价

<https://cloud.google.com/vpc/network-pricing>

IPv4、IPv6、Cloud NAT 与流量另行核价。免费算力不等于整个部署零费用。

[S17] Google Cloud：预算与提醒

<https://docs.cloud.google.com/billing/docs/how-to/budgets>

Alerts-only 预算用于提醒，不是自动扣费封顶；费用数据可能延迟。

[S18] Google Cloud：Spend cap budgets

<https://docs.cloud.google.com/billing/docs/how-to/budgets-spend-caps>

预览版预算封顶仅适用特定服务，且不会停止持续计算与存储资源的费用。

[S19] Oracle Cloud：Always Free

https://docs.oracle.com/en-us/iaas/Content/FreeTier/freetier_topic-Always_Free_Resources.htm

当前免费计算与存储资源、主区域限制、容量不足和空闲实例回收要求。

[S20] Google Cloud：E2 机型规格

https://docs.cloud.google.com/compute/docs/general-purpose-machines#e2_shared-core

e2-micro 是共享 CPU、约 1 GB 内存的小规格，需先测试应用与 AI CLI 的峰值内存。

[S21] Google Cloud：创建虚拟机

<https://docs.cloud.google.com/compute/docs/instances/create-start-instance>

控制台创建实例的基础流程。实际区域、机型、磁盘与计费选项须在提交前复核。

用户提供的补充阅读（本次返回 403，正文未核验）：<https://zhuanlan.zhihu.com/p/1977711962109538485>。未作为额度、价格或部署步骤的事实来源。